



SERVER CARD

SRV-01

EMAIL SERVER

TYPE: Business Critical
COST: 8 Budget
CAPACITY: 1 service
COMPLEXITY: 2/4
AVAILABILITY REQUIREMENT: 99.9% (almost always needed)
NETWORK PLACEMENT: DMZ or protected segment (external access required)

DESCRIPTION
Central email system (Exchange, Postfix, or cloud-based like Office 365). Handles all organizational communication. Commonly targeted by phishing and credential attacks. Must support spam filtering, encryption, and audit logging.

KEY CONCERNS
Email spoofing and phishing vectors; Credential compromise (email = access to password resets); Data exfiltration via email attachments and forwarding; High user impact if unavailable;

DEFENSE CONSIDERATIONS
Requires Email Authentication (DMARC/SPF/DKIM); Benefits from DLP for sensitive email attachments; Gateway filtering for phishing and malware; MFA required for administrative access;

INTERACTIONS
Used with Asset Card "Email"; References in Incident Response scenarios (T-01 Phishing, T-11 Browser Extension); Part of Disaster Recovery "critical services" list;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-02

WEB SERVER

TYPE: Business Critical
COST: 7 Budget
CAPACITY: 1 service
COMPLEXITY: 2/4
AVAILABILITY REQUIREMENT: 99.5% (critical during business hours)
NETWORK PLACEMENT: DMZ (external access required, isolated from internal systems)

DESCRIPTION
Web application server (Apache, Nginx, IIS). Hosts corporate website, customer portal, or SaaS application. Primary attack surface for web exploits (SQL injection, XSS, remote code execution).

KEY CONCERNS
Application vulnerabilities (OWASP Top 10); Unpatched framework or library exploits; DDoS attacks targeting availability; Code injection and remote execution; Data exposure via web interface;

DEFENSE CONSIDERATIONS
Requires WAF (Web Application Firewall) for SQL injection/XSS prevention; IPS for exploit signature detection; Regular patching and vulnerability scanning; Load balancer for availability; TLS/SSL for data in transit;

INTERACTIONS
Used with Asset Card "Web"; References in Incident Response scenarios (T-02 Watering Hole, T-05 Kernel Exploit); Load balancer reduces single point of failure;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-03

DATABASE SERVER

TYPE: Business Critical
COST: 10 Budget
CAPACITY: 1 service
COMPLEXITY: 3/4
AVAILABILITY REQUIREMENT: 99.9% (critical for business operations)
NETWORK PLACEMENT: Restricted segment (only authorized systems can connect)

DESCRIPTION
Relational or NoSQL database (SQL Server, PostgreSQL, MongoDB, Oracle). Stores customer data, financial records, operational data. Highest value target after compromise-contains the "crown jewels."

KEY CONCERNS
SQL injection attacks; Credential abuse (weak database admin passwords); Lateral movement target (pivot point); Unencrypted data at rest; Unencrypted data in transit; Unauthorized data access and exfiltration;

DEFENSE CONSIDERATIONS
Requires Network Segmentation to limit access; Credential Guard and strong authentication; Database activity monitoring (DAM); TLS for all connections; Data encryption at rest; Regular backups with immutability; Connection string in vault (not hardcoded);

INTERACTIONS
Used with Asset Card "Database"; References in Incident Response scenarios (T-04 Lateral Movement, T-10 SQL Exfiltration, T-11 Browser Extension); Critical for Disaster Recovery backup and recovery;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-04

FILE SERVER

TYPE: Business Critical
COST: 6 Budget
CAPACITY: 2 services
COMPLEXITY: 2/4
AVAILABILITY REQUIREMENT: 99% (needed during business hours)
NETWORK PLACEMENT: Protected segment (limited internal access only)

DESCRIPTION
File storage and sharing system (SMB/CIFS, NFS, or cloud file sharing). Stores shared documents, project files, compliance records. Often contains both sensitive and non-sensitive data mixed together.

KEY CONCERNS
SMB lateral movement attacks; Excessive file permissions (everyone can read everything); Ransomware encryption of shares; Unauthorized file access and data theft; Compliance violations (PII, PHI, PCI data stored unencrypted); Uncontrolled data growth and backup challenges;

DEFENSE CONSIDERATIONS
Network Segmentation to limit SMB access; File permissions auditing and hardening; DLP for sensitive file detection; Imutable snapshots for ransomware recovery; Encryption at rest; Access logging and monitoring;

INTERACTIONS
Used with Asset Card "File Storage"; Target of T-04 Lateral Movement in Incident Response; Critical dependency for Disaster Recovery;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-05

DOMAIN CONTROLLER

TYPE: Business Critical
COST: 12 Budget
CAPACITY: 2 services
COMPLEXITY: 3/4
AVAILABILITY REQUIREMENT: 99.5% (core infrastructure dependency)
NETWORK PLACEMENT: Restricted segment (admin-only access)

DESCRIPTION
Active Directory or LDAP domain controller. Master repository of all user identities, credentials, and group memberships. Most powerful target in the organization-compromise of DC gives attacker control of entire directory.

KEY CONCERNS
Credential dumping (Mimikatz targets LSASS on DC); Pass-the-hash attacks; Unauthorized privilege escalation; DC compromise = organization is fundamentally compromised; Backup DC synchronization complications; Can be both on-premises and cloud (Azure AD);

DEFENSE CONSIDERATIONS
Credential Guard to protect LSASS; Privileged Access Workstation (PAW) for DC admin access; Strong authentication (MFA) for all DC access; Network Segmentation (DC in restricted tier); Backup DC in geographically separate location; Regular backup and recovery testing;

INTERACTIONS
Used with Asset Card "Identity"; Central to Incident Response investigation (T-06 Mimikatz, T-04 Lateral Movement); DC compromise immediately loses the game (organizational control lost); Critical for Disaster Recovery restore procedures;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-06

DEVELOPMENT SERVER

TYPE: Business Important
COST: 5 Budget
CAPACITY: 3 services
COMPLEXITY: 2/4
AVAILABILITY REQUIREMENT: 80% (nice to have, can work around)
NETWORK PLACEMENT: Development segment (isolated from production)

DESCRIPTION
Development and testing environment for software development. Lower security requirements than production but often contains production-like data (for testing). Developers need broad access for testing purposes.

KEY CONCERNS
Overly permissive developer access; Production data in dev (compliance violations); Outdated/unpatched tools (focus on development, not security); Lateral movement springboard to production; Code repository contains source code (intellectual property); Test credentials and API keys hardcoded;

DEFENSE CONSIDERATIONS
Separate dev database from production database (never use prod data); Firewall rules to prevent dev-prod lateral movement; Code repository security (secrets scanning, access control); Regular cleanup of test data; MFA for dev server access; Audit logging of developer activities;

INTERACTIONS
Used with Asset Card "Development"; Often overlooked security risk (compliance gap in Audit module); Lateral movement target (attacker compromise dev to move to prod);

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-07

BACKUP SERVER

TYPE: Business Critical (Different Tier)
COST: 9 Budget
CAPACITY: 1 service
COMPLEXITY: 2/4
AVAILABILITY REQUIREMENT: 95% (needed for recovery scenarios)
NETWORK PLACEMENT: Restricted segment + offsite (separate from primary network)

DESCRIPTION
Backup and archival storage system (dedicated appliance, NAS, or cloud backup like Veeam, Commvault, or Backblaze). Stores point-in-time copies of all critical systems. The ultimate recovery mechanism for ransomware, disasters, and destructive attacks.

KEY CONCERNS
Backup corruption or compromise (renders backups useless); Ransomware targeting backup systems; Backup media not separated from primary systems; Backups not regularly tested (recovery fails when needed); Immutability not enforced (backups can be modified); Access control: who can restore? Who can delete?;

DEFENSE CONSIDERATIONS
CRITICAL: 3-2-1 backup strategy: 3 copies, 2 media types, 1 offsite; Imutable backups (WORM - Write Once Read Many); Encryption at rest and in transit; Backup testing schedule (quarterly minimum); Separate backup credentials (not domain-linked); Offsite backup location (geographically separated); Backup media inventory and audit log;

INTERACTIONS
Used with Asset Card "Disaster Recovery"; Critical for Disaster Recovery module (backup resilience determines recovery speed); If backup is missing or compromised, the team automatically FAILS the Disaster Recovery requirement (v2.2) - a CRITICAL gap carried into other modules; Incident Response mentions backup verification in defenses;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-08

CLOUD WORKLOAD

TYPE: Increasingly Business Critical
COST: 4 Budget
CAPACITY: 2 services
COMPLEXITY: 2/4 (But different concerns than on-premises)
AVAILABILITY REQUIREMENT: 99% (vendor manages SLA)
NETWORK PLACEMENT: Cloud provider network (separate from on-premises, connected via VPN)

DESCRIPTION
Cloud-hosted application or service (AWS EC2, Azure VM, GCP Compute Engine, or fully managed service like Lambda, Cloud Run). Shifts some infrastructure management to cloud provider but introduces new security concerns.

KEY CONCERNS
Misconfigured security groups/network ACLs (open to internet); Cloud credentials compromise (AWS IAM keys stolen); Instance metadata service attacks (AWS IMDS exploitation); Cross-account or cross-tenant access (shared infrastructure); Cloud-specific vulnerabilities (API, permissions models); Data residency and compliance (where is data stored?);

DEFENSE CONSIDERATIONS
Cloud-native security tools (AWS Security Hub, Azure Security Center); Proper IAM configuration (least privilege for cloud roles); Network security groups with default-deny; Cloud workload protection (container runtime security); VPC and subnet isolation; Encryption of cloud data;

INTERACTIONS
Used with Asset Card (varies-Email in cloud, Web in cloud, etc.); Network design must include cloud connectivity (VPN or Direct Connect); Audit module assesses cloud security posture; Cloud-specific Incident Response and Hardening challenges;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-09

LEGACY SYSTEM

TYPE: Business Important (Legacy)
COST: 3 Budget
CAPACITY: 1 service
COMPLEXITY: 3/4 (difficult to maintain, patch, or secure)
AVAILABILITY REQUIREMENT: 90% (supported but aging)
NETWORK PLACEMENT: Isolated segment (strict firewall rules, minimal connectivity)

DESCRIPTION
Aging system running outdated OS (Windows XP, older Linux, proprietary systems) or custom applications. Cannot be easily patched due to compatibility issues, vendor no longer supporting, or critical business process depends on it.

KEY CONCERNS
Cannot patch due to vendor EOL (End of Life); Incompatible with modern security tools (EDR won't run); No TLS support (unencrypted traffic); Known, publicly disclosed vulnerabilities with no fix; Business relies on it despite security risk; Migration cost exceeds security benefit (economically trapped);

DEFENSE CONSIDERATIONS
CRITICAL: Network Segmentation isolates legacy system; Firewall rules restrict legacy system traffic; Assume compromise and defend the segmented network (not the legacy system itself); Monitor legacy system for suspicious activity (can't detect on system, detect on network); Imutable backups to restore if compromised; Plan legacy system retirement;

INTERACTIONS
Used if organization has legacy infrastructure; Audit module finds legacy systems as critical findings; Network design: "assume legacy is compromised, defend around it"; Expansion deck explores legacy system challenges;

INCIDENT ZERO - NETWORK BUILDING



SERVER CARD

SRV-10

HONEYPOT DECOY

TYPE: Security Tool (Non-Business)
COST: 7 Budget
CAPACITY: 1 service (decoy only - hosts no real business service)
COMPLEXITY: 1/4 (purposefully simple and unmonitored-looking)
AVAILABILITY REQUIREMENT: N/A (false resource)
NETWORK PLACEMENT: Among legitimate resources (cannot appear isolated)

DESCRIPTION
Deliberately exposed fake server or user account designed to detect compromise and lateral movement. Appears to be a real business resource but is actually a trap. Any access to honeypot indicates active attacker activity (zero false positives).

KEY CONCERNS
Placement visibility (attacker must discover it to trigger it); Believability (must look like real system worth attacking); Monitoring (honeypot access must be logged securely); Honeypot maintenance (must not appear unmaintained); Response procedures (what do we do when honeypot is triggered?);

DEFENSE CONSIDERATIONS
Canary tokens (watermarked documents, fake credentials); Fake administrative account (admin account that isn't really admin); Fake file server with sensitive-looking shares; Fake VIP email addresses on mailing lists; Alerting on any access to honeypot (immediate incident response);

INTERACTIONS
Used with Deception Technology defense card in Hardening; Network design: "place honeypots where attackers will likely look"; Zero false positives; any honeypot access = real attack; Expansion deck discusses advanced honeypot strategies;

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-01

FIREWALL (PERIMETER)

TYPE: Perimeter Control
COST: 12 Budget
PLACEMENT: Network edge (between internet and internal network)
PRIMARY FUNCTION: Block unauthorized inbound/outbound traffic
RULESET COMPLEXITY: Medium (5-10 rules for basic setup, 50+ for mature organization)
PERFORMANCE IMPACT: Minimal for small networks, can become bottleneck at scale

DESCRIPTION
Traditional stateful firewall (Cisco ASA, Palo Alto Networks, Fortinet FortiGate) at network perimeter. Enforces allow/deny rules based on source IP, destination IP, protocol, and port. First line of defense against external attacks.

WHAT IT PROTECTS AGAINST
Unauthorized inbound access attempts; Unauthorized outbound connections (C2 beaconing, data exfiltration); Network reconnaissance from internet; DDoS attacks (basic flood protection);

WHAT IT DOESN'T PROTECT AGAINST
Application-layer attacks (SQL injection, XSS); Lateral movement within network (operates at L3/L4 only); Encrypted traffic inspection (needs deep packet inspection); Insider threats or authorized-but-malicious access;

NETWORK INTERACTIONS
Required for: Most organizations (perimeter protection is baseline); Works with: Web Server (must allow inbound HTTP/HTTPS), Email Server (SMTP/POP3/IMAP); Supports: Database (prevents inbound database connections from internet);

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-02

INTRUSION DETECTION SYSTEM (IDS)

TYPE: Threat Detection
COST: 10 Budget
PLACEMENT: Internal network (behind firewall, in front of critical systems)
PRIMARY FUNCTION: Detect suspicious network traffic patterns
SIGNATURE MAINTENANCE: High (requires weekly/daily signature updates from threat intelligence)
PERFORMANCE IMPACT: Medium (packet inspection adds latency, can slow network)

DESCRIPTION
Network-based IDS (Snort, Zeek, Suricata) that inspects all traffic and alerts on suspicious patterns. Uses signature matching and/or behavioral analysis to identify known attacks and anomalous traffic.

WHAT IT PROTECTS AGAINST
Known attack patterns (exploits, vulnerability scans); Port scanning and reconnaissance; Lateral movement (SMB, RDP abuse); Data exfiltration patterns (unusual volume, unusual destination); Command & Control (C2) communication;

WHAT IT DOESN'T PROTECT AGAINST
Zero-day exploits (no signature exists); Encryption inspection (needs decryption); Insider threats (authorized users on authorized systems); Application-layer attacks (SQL injection, XSS still pass through);

NETWORK INTERACTIONS
Works with: SIEM (IDS alerts feed into SIEM for correlation); Supports: Detection of T-04 (Lateral Movement), T-09 (C2 Beaconing) in Incident Response; Complements: IPS (IDS detects, IPS blocks; often paired);

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-03

INTRUSION PREVENTION SYSTEM (IPS)

TYPE: Threat Prevention
COST: 14 Budget
PLACEMENT: Internal network (actively blocks malicious traffic)
PRIMARY FUNCTION: Block suspicious traffic in real-time
TUNING COMPLEXITY: High (false positives require tuning; too aggressive = blocks legitimate traffic)
PERFORMANCE IMPACT: Medium-High (real-time inspection + blocking adds latency)
RISK: Misconfigured IPS can block critical business traffic

DESCRIPTION
Network-based IPS (actively protective version of IDS). Can block traffic in addition to alerting. Inline placement allows real-time threat blocking.

WHAT IT PROTECTS AGAINST
Everything IDS protects against (detection + blocking); Exploit attempts against known vulnerabilities; Worm propagation; Policy violations;

WHAT IT DOESN'T PROTECT AGAINST
Same limitations as IDS, plus; False positive blocking (can block legitimate traffic); Encrypted traffic inspection limitations; Zero-day exploits;

NETWORK INTERACTIONS
Works with: WAF on web traffic (IPS for network, WAF for applications); Works with: Firewall (layered network defense); Supports: Defense against T-02 (Watering Hole), T-05 (Kernel Exploit) in Incident Response;

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-04

LOAD BALANCER

TYPE: Availability & Performance
COST: 8 Budget
PLACEMENT: In front of multiple web servers
PRIMARY FUNCTION: Distribute traffic across multiple servers
HEALTH CHECK MECHANISM: Monitors backend servers; removes unhealthy servers automatically
COST-BENEFIT: Low cost (8 Budget) but high value if you have multiple web servers

DESCRIPTION
Load balancer (F5, Citrix NetScaler, nginx, HAProxy) distributes incoming traffic across multiple backend servers. Increases availability and performance.

WHAT IT PROTECTS AGAINST
Single server failure (if one web server fails, traffic routes to others); DDoS attacks (distributes attack traffic across multiple servers); Overload attacks (can queue excess requests);

WHAT IT DOESN'T PROTECT AGAINST
Application vulnerabilities; Malicious traffic targeting multiple backends; Session hijacking; Backend compromise (load balancer can't protect compromised backend);

NETWORK INTERACTIONS
Requires: Web Server (needs multiple instances for load balancing to make sense); Works with: Web Server redundancy (2+ web servers behind load balancer); Supports: Web application availability in Incident Response scenarios;

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-05

VPN GATEWAY

TYPE: Remote Access Control
COST: 9 Budget
PLACEMENT: Network perimeter (between internet and internal network)
PRIMARY FUNCTION: Secure remote access for employees/contractors
AUTHENTICATION COMPLEXITY: Requires MFA for security (otherwise easy brute force)
COST-BENEFIT: Necessary for remote work, but alone insufficient (needs MFA)

DESCRIPTION
VPN concentrator (Cisco AnyConnect, Palo Alto Prisma Access, F5 BIG-IP) that creates encrypted tunnels for remote users. Allows employees to securely access internal resources from outside network.

WHAT IT PROTECTS AGAINST
Man-in-the-middle attacks on remote user traffic; Credential interception (traffic encrypted); Unauthorized access to internal resources (authentication required); IP spoofing (tunnel validates source);

WHAT IT DOESN'T PROTECT AGAINST
Weak VPN credentials (still vulnerable to brute force); Compromised endpoint connecting via VPN (malware on home computer); Insider threats (authorized user with legitimate credentials); Application vulnerabilities accessed through VPN;

NETWORK INTERACTIONS
Works with: Domain Controller (VPN user auth); Works with: MFA (VPN should require MFA); Supports: Remote work scenarios (necessary for distributed teams);

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-06

EMAIL GATEWAY

TYPE: Email Security
COST: 6 Budget
PLACEMENT: Network perimeter (filters incoming/outgoing email)
PRIMARY FUNCTION: Filter spam, phishing, and malware in email
SIGNATURE MAINTENANCE: Very high (email threats change daily)
USER EXPERIENCE IMPACT: Email delays (milliseconds) are imperceptible; false positives = missed emails

DESCRIPTION
Email security appliance (Proofpoint, Mimecast, Cisco Email Security) that filters all incoming/outgoing email. Scans for phishing, malware, data exfiltration attempts.

WHAT IT PROTECTS AGAINST
Phishing emails (signature and behavior-based detection); Email-based malware (attachments, links); Spam (reduces alert fatigue); Data exfiltration via email (DLP for email); Email spoofing (validates SPF/DKIM/DMARC);

WHAT IT DOESN'T PROTECT AGAINST
User clicks on phishing links (user training needed); Advanced phishing with legitimate credentials; Compromised internal email account sending from inside; Zero-day malware in attachments;

NETWORK INTERACTIONS
Works with: Email Server (filters before reaching server); Works with: User Security Training (filters + training = defense-in-depth); Supports: Defense against T-01 (Phishing) in Incident Response;

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-07

WEB APPLICATION FIREWALL (WAF)

TYPE: Application-Layer Protection
COST: 11 Budget
PLACEMENT: In front of web server
PRIMARY FUNCTION: Block application-layer attacks (SQL injection, XSS, etc.)
RULE MAINTENANCE: Medium (OWASP rules are standardized, vendor maintains them)
FALSE POSITIVE RATE: Medium (needs tuning for specific web application)
PERFORMANCE IMPACT: Medium (application inspection adds latency)

DESCRIPTION
Web Application Firewall (ModSecurity, Cloudflare WAF, AWS WAF) that inspects HTTP traffic and blocks malicious payloads. Understands web application protocols unlike traditional firewall.

WHAT IT PROTECTS AGAINST
SQL injection attacks; Cross-site scripting (XSS); Cross-site request forgery (CSRF); Remote code execution (RCE); Malicious file uploads; Buffer overflows in web apps;

WHAT IT DOESN'T PROTECT AGAINST
Logic flaws in application (WAF can't fix broken business logic); Authenticated attacks (user is authorized); Distributed attacks across many IPs (WAF can't distinguish); Zero-day application vulnerabilities (no rule exists);

NETWORK INTERACTIONS
Requires: Web Server (only protects web traffic); Works with: IPS (network-level and application-level defense); Supports: Defense against T-02 (Watering Hole) in Incident Response;

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-08

NETWORK SEGMENTATION SWITCH

TYPE: Network Architecture Control
COST: 10 Budget
PLACEMENT: Internal network (between segmented network zones)
PRIMARY FUNCTION: Enforce network segmentation via VLANs and ACLs
CONFIGURATION COMPLEXITY: High (requires planning of segment boundaries and rules)
COST-BENEFIT: Very high ROI (prevents lateral movement for 10 Budget)

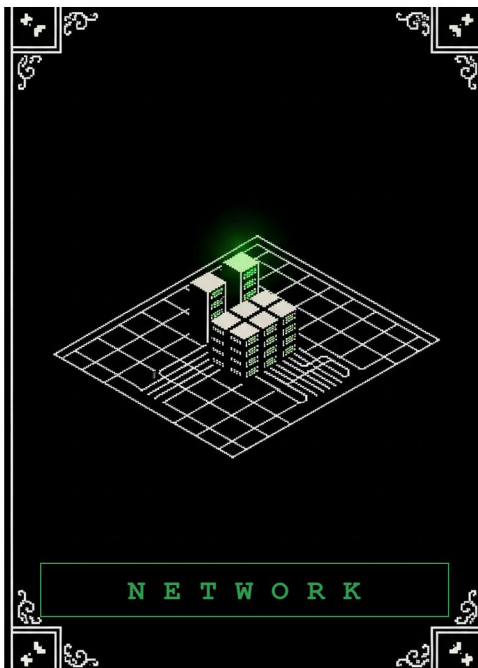
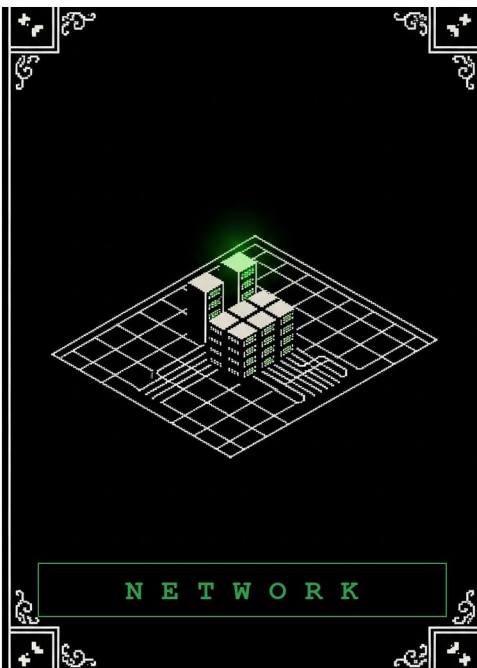
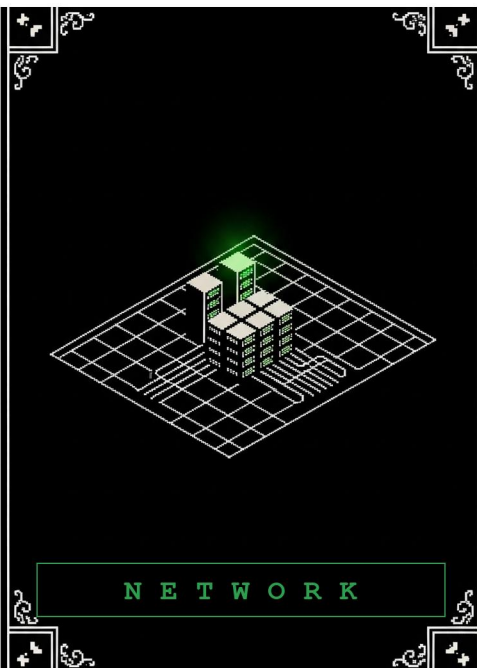
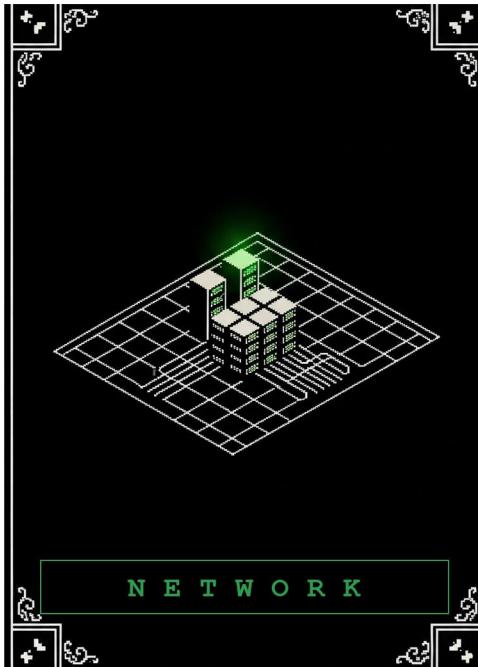
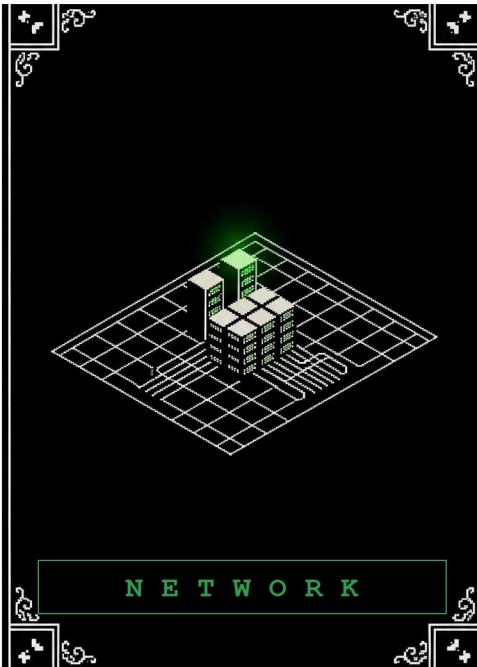
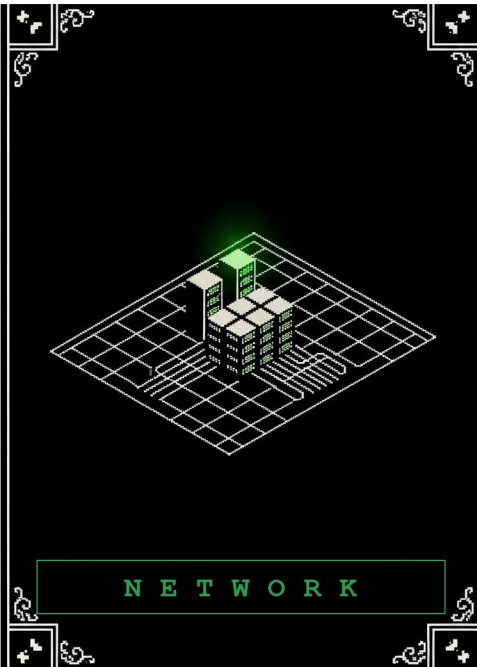
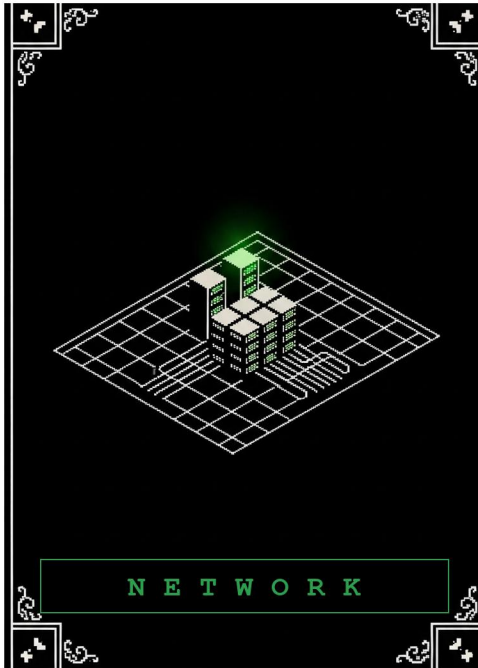
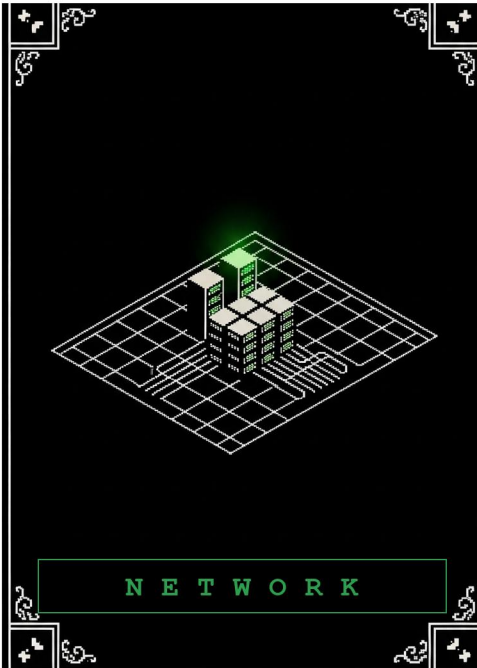
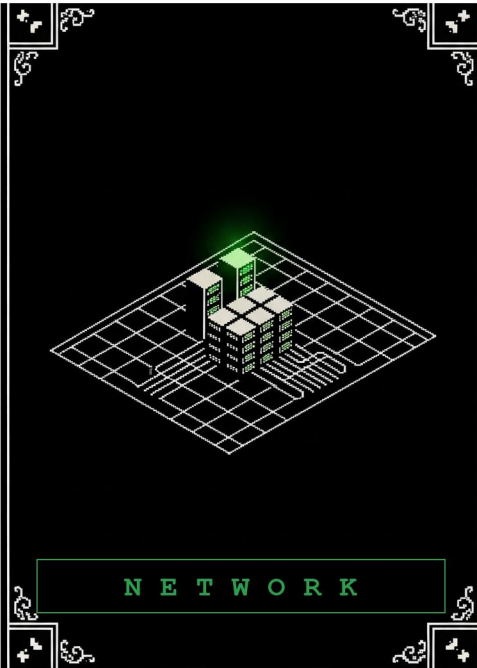
DESCRIPTION
Layer 3 switch or router configured for network segmentation. Implements VLANs (virtual LANs) and layer 3 filtering to separate network into zones (DMZ, User segment, Server segment, Admin segment).

WHAT IT PROTECTS AGAINST
Lateral movement via SMB and other internal protocols; Credential dumping spread (isolated networks can't reach DCs); Compromised user system accessing servers directly; Insider threats (restrictions on data access); Data exfiltration to external media (if USB segment is isolated);

WHAT IT DOESN'T PROTECT AGAINST
Attacks within same segment (switch can't prevent user-user attacks); Routing around segmentation (if misconfigured); Physical network attacks (layer 1 problems); Encrypted tunneling out of segment (if firewall rule allows);

NETWORK INTERACTIONS
Works with: Firewall (firewall rules enforce segmentation policies); Works with: Database Server (database in isolated segment); Works with: Zero Trust (segmentation is prerequisite for zero trust); Supports: Defense against T-04 (Lateral Movement) in Incident Response;

INCIDENT ZERO - NETWORK BUILDING





DEVICE CARD

SEC-09

SIEM (SECURITY INFORMATION & EVENT MANAGEMENT)

TYPE: Threat Monitoring & Investigation

COST: 15 Budget

PLACEMENT: Central monitoring (logs from all devices)

PRIMARY FUNCTION: Aggregate logs and detect threats via correlation

DATA REQUIREMENTS: Massive (can be 10+ GB/day for large organizations)

MAINTENANCE: Very high (tuning rules, managing data retention, responding to false positives)

VALUE: Essential for organizations that need incident detection

DESCRIPTION

Enterprise SIEM (Splunk, Elastic, Qadar, ArcSight) that collects logs from all systems, correlates events, and alerts on suspicious patterns. Foundation of mature incident response program.

WHAT IT PROTECTS AGAINST

Multi-step attack patterns (correlation finds chains); Persistence mechanisms (scheduled tasks, registry changes logged); Credential abuse (failed login spikes); Insider threats (excessive file access, off-hours activity); Data exfiltration (unusual volume to unusual destination);

WHAT IT DOESN'T PROTECT AGAINST

Attacks happening faster than SIEM ingests logs; False negatives (misconfigured rules miss attacks); Encrypted traffic inspection (needs decryption); Malware on endpoint (needs EDR, not SIEM);

NETWORK INTERACTIONS

Requires: Log Centralization deployment (needs logs to analyze); Works with: IDS/IPS alerts (SIEM correlates with network alerts); Supports: Incident Response Investigation (SIEM data essential for forensics); Critical for: Hardening module detection (SIEM detects Pentester Tactics);

INCIDENT ZERO - NETWORK BUILDING



DEVICE CARD

SEC-10

HONEYPOT NETWORK

TYPE: Deception & Detection

COST: 8 Budget

PLACEMENT: Isolated segment (mimics legitimate infrastructure)

PRIMARY FUNCTION: Detect lateral movement and reconnaissance

MAINTENANCE: Medium (must keep honeypot looking alive and attractive)

COST-BENEFIT: Low cost (8 Budget) with high detection value (zero false positives)

DESCRIPTION

Network of decoy systems (not SRV-10 honeypot server, but entire segment) designed to attract attackers. Any access to honeypot network indicates active attacker.

WHAT IT PROTECTS AGAINST

Lateral movement (attacker triggers honeypot while exploring); Network reconnaissance (if honeypot is discovered); Ransomware spread (if honeypot is in ransomware path); Insider reconnaissance (any access to honeypot = red flag);

WHAT IT DOESN'T PROTECT AGAINST

Attacks that don't trigger honeypot (if attacker follows direct path); Honeypot visibility (attacker must find it to trigger it); False positives (must be designed to avoid accidental triggers);

NETWORK INTERACTIONS

Works with: Network Segmentation (honeypot in isolated but accessible segment); Works with: SIEM (honeypot triggers feed into SIEM); Supports: Detection in Hardening module (Deception Technology defense);

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-01

EMAIL

BUSINESS FUNCTION: Internal and external email communication

CRITICALITY: High (nearly universal requirement)

IMPACT IF DOWN: Significant (communication stops, customer requests missed)

COMPLIANCE REQUIREMENTS: Email retention (SOX, GDPR), encryption (HIPAA, PCI-DSS)

DESCRIPTION

Organization needs reliable email system for internal communication and external customer contact. Email is both critical infrastructure and significant security risk (phishing, credential attacks, data exfiltration).

NETWORK REQUIREMENTS

Server: Email Server (SRV-01); Protection: Email Gateway (SEC-06) for phishing/malware filtering; Optional: Load Balancer if email server needs redundancy;

SECURITY CONSIDERATIONS

Email is primary phishing attack vector (T-01 in Incident Response); Email contains sensitive information (must be encrypted and access-controlled); Email forwarding rules can be abused for data exfiltration; Email archive must be protected and retained per compliance requirements;

DEPENDENCIES

Requires Domain Controller for user authentication; Requires backup for email archive recovery; Integrates with SIEM for email security event logging;

TEAM DESIGN VALIDATION

✓ Must Include: Email Server or equivalent email service (cloud-based OK) ✓ Should Include: Email Gateway for threat filtering ✓ Failure Condition: No email capability = cannot satisfy Asset requirement

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-02

WEB

BUSINESS FUNCTION: Public-facing web application or website

CRITICALITY: Medium (business depends on it but alternatives exist)

IMPACT IF DOWN: Moderate (customers cannot access services, lost sales/engagement)

COMPLIANCE REQUIREMENTS: PCI-DSS (if payments), WCAG accessibility

DESCRIPTION

Organization has public web presence—either corporate website, e-commerce site, or customer portal. Web server is exposed to internet and primary target for web exploits (SQL injection, RCE, DDoS).

NETWORK REQUIREMENTS

Server: Web Server (SRV-02) in DMZ; Protection: WAF (SEC-07) for application-layer attack prevention; Optional: Load Balancer (SEC-04) for redundancy and DDoS protection;

SECURITY CONSIDERATIONS

Web servers have highest internet attack surface; Vulnerable to web exploits (T-02 Watering Hole, T-05 Kernel Exploit in Incident Response); DDoS attacks can take down web server; Code injection can compromise entire application; Requires patching and web application security testing;

DEPENDENCIES

Often connects to Database (for dynamic content); May require load balancer for redundancy; Requires SIEM monitoring for web security events;

TEAM DESIGN VALIDATION

✓ Must Include: Web Server (SRV-02) or cloud-hosted web service ✓ Should Include: WAF for attack protection ✓ Should Include: Load Balancer if redundancy needed ✗ Failure Condition: No web server = Asset unsatisfied

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-03

DATABASE

BUSINESS FUNCTION: Data storage and retrieval for critical business data

CRITICALITY: Very High (most sensitive business data)

IMPACT IF DOWN: Severe (business cannot operate, financial/customer impact)

COMPLIANCE REQUIREMENTS: PCI-DSS, HIPAA, GDPR, SOX (depending on data type)

DESCRIPTION

Centralized database for customer data, financial records, operational data. Database is most valuable attack target—contains the "crown jewels." Database compromise often defines loss condition in Incident Response.

NETWORK REQUIREMENTS

Server: Database Server (SRV-03) in restricted/admin segment; Protection: Network Segmentation (SEC-08) to limit access; Optional: Backup Server (SRV-07) for recovery capability;

SECURITY CONSIDERATIONS

Database is primary exfiltration target (T-10, T-11 in Incident Response); SQL injection attacks compromise database; Credential abuse allows unauthorized access to sensitive data; Data exfiltration is often attack goal (customer PII, financial data); Database compromise may be game-loss condition; Must have immutable backups for recovery from ransomware;

DEPENDENCIES

Requires strong authentication (MFA, password vault); Requires Data Loss Prevention (DLP) to prevent exfiltration; Requires encryption at rest and in transit; Requires database activity monitoring (DAM) for audit;

TEAM DESIGN VALIDATION

✓ Must Include: Database Server or equivalent data store (Cloud Workload hosting is allowed but is a recorded risk) ✓ Should Include: Network Segmentation to isolate database access ✓ Should Include: Backup Server for disaster recovery ✗ Failure Condition: No database = Asset unsatisfied OR unsecured database access = audit finding

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-04

FILE STORAGE

BUSINESS FUNCTION: Shared file storage for documents, projects, compliance records

CRITICALITY: High (business relies on shared documents)

IMPACT IF DOWN: Moderate-High (work stops, cannot access needed files)

COMPLIANCE REQUIREMENTS: Data retention (GDPR), data classification (HIPAA, PCI-DSS)

DESCRIPTION

Shared network file storage for collaborative work. File servers often contain mixed-sensitivity data (company policy next to customer PII next to trade secrets). Poorly secured file storage is source of data exfiltration and lateral movement.

NETWORK REQUIREMENTS

Server: File Server (SRV-04) in protected segment; Protection: Network Segmentation (SEC-08) to limit file access; Optional: DLP (in Hardening module) to prevent sensitive file exfiltration;

SECURITY CONSIDERATIONS

File servers are lateral movement target (T-04 in Incident Response); SMB protocol allows attacker to enumerate shares and attempt access; Over-permissive file permissions = data exfiltration vector; Ransomware frequently targets file servers (T-11 in Incident Response); File permissions audit is critical for compliance;

DEPENDENCIES

Requires Domain Controller for user authentication; Requires Network Segmentation to limit SMB access; Requires backup strategy (especially for ransomware recovery); Requires file permission auditing;

TEAM DESIGN VALIDATION

✓ Must Include: File Server or cloud file storage (OneDrive, SharePoint, Google Drive) ✓ Should Include: Network Segmentation to restrict access ✓ Should Include: Backup for ransomware recovery ✗ Failure Condition: No file storage = Asset unsatisfied

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-05

IDENTITY

BUSINESS FUNCTION: User identity and access management

CRITICALITY: Very High (foundational to all access control)

IMPACT IF DOWN: Severe (cannot authenticate users, cannot operate)

COMPLIANCE REQUIREMENTS: MFA (various standards), audit logging (GDPR, SOX)

DESCRIPTION

Centralized identity system (Active Directory, Azure AD, Okta) that authenticates users and grants access to resources. Identity compromise is game-over scenario—attacker with access to identity system can impersonate any user.

NETWORK REQUIREMENTS

Server: Domain Controller (SRV-05) in admin segment; Protection: Network Segmentation Switch (SEC-08) – keep the DC in an isolated admin zone; Optional: Second Domain Controller for redundancy (full price);

SECURITY CONSIDERATIONS

Domain Controller is most sensitive system (compromise = total infrastructure access); Credential dumping attacks target DC (T-06 Mimikatz in Incident Response); Compromised DC allows attacker to create backdoor accounts; Pass-the-hash attacks replay credentials from DC compromise; DC must be in isolated segment with strict access control;

DEPENDENCIES

Requires strong authentication (MFA for all DC access); Requires privileged access workstation (PAW) for admin access; Requires immutable backup DC in separate location; Requires audit logging of all DC changes;

TEAM DESIGN VALIDATION

✓ Must Include: Domain Controller (on-premises or Azure AD) ✓ Should Include: Network Segmentation (isolated admin zone) ✓ Should Include: Second Domain Controller for redundancy (optional, full price) ✗ Failure Condition: No identity system = the identity requirement is unsatisfied (design incomplete)

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-06

DEVELOPMENT

BUSINESS FUNCTION: Software development and testing environment

CRITICALITY: Medium (important but not production-critical)

REQUIREMENT STRENGTH: Recommended (v2.2) – may be satisfied by overloading another server (+1 Budget per extra service)

IMPACT IF DOWN: Low-Medium (development delays, but not immediate business impact)

COMPLIANCE REQUIREMENTS: Secrets management (API keys not hardcoded), code scanning

DESCRIPTION

Development and testing infrastructure where software developers build and test applications. Development environment is often overlooked security risk because developers prioritize speed over security.

NETWORK REQUIREMENTS

Server: Development Server (SRV-06) in isolated development segment; Protection: Firewall rules prevent dev-prod lateral movement; Optional: Code repository (Git, GitHub) for version control;

SECURITY CONSIDERATIONS

Development servers often contain production-like data (compliance violation); Developers have broad access (weak access controls); Test credentials and API keys in source code; Outdated/unpatched tools (developer tools not security tools); Development system as lateral movement springboard to production; Source code repository is high-value target (intellectual property);

DEPENDENCIES

Requires separate database from production (never use production data in dev); Requires code review and secrets scanning; Requires Firewall rules isolating dev from production; Requires MFA for code repository access;

TEAM DESIGN VALIDATION

✓ Should Include: Development Server, OR dev services overloaded onto another server (allowed, +1 Budget) ✓ Should Isolate: Dev network from production network ✓ Should Scan: Code for hardcoded secrets ✗ Failure Condition: Using production database in dev = data exposure/compliance violation

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-07

DISASTER RECOVERY

BUSINESS FUNCTION: Recovery capability for business continuity

CRITICALITY: Very High (determines if business survives major attack/disaster)

REQUIREMENT STRENGTH: Required (v2.2)

IMPACT IF DOWN: Catastrophic (cannot recover from major incident)

COMPLIANCE REQUIREMENTS: Backup retention, recovery SLA (RTO/RPO)

DESCRIPTION

Backup and disaster recovery capability. Organization needs ability to recover from data loss, ransomware, or disaster. Backup/recovery capability is often neglected until it's needed.

NETWORK REQUIREMENTS

Server: Backup Server (SRV-07) with off-site backups; Protection: Immutable backups (WORM storage); 3-2-1 Strategy: 3 copies, 2 media types, 1 off-site;

SECURITY CONSIDERATIONS

Ransomware attacks target backup systems (T-11 in Incident Response); Backup must be immutable (attacker cannot modify backups); Backup must be off-site (local backup lost if data center destroyed); Backup testing must be regular (quarterly minimum); Backup credentials must be separate from domain (attacker cannot delete backups);

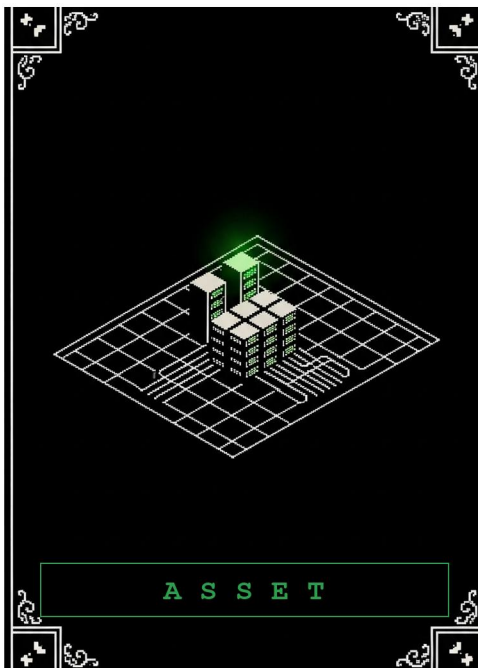
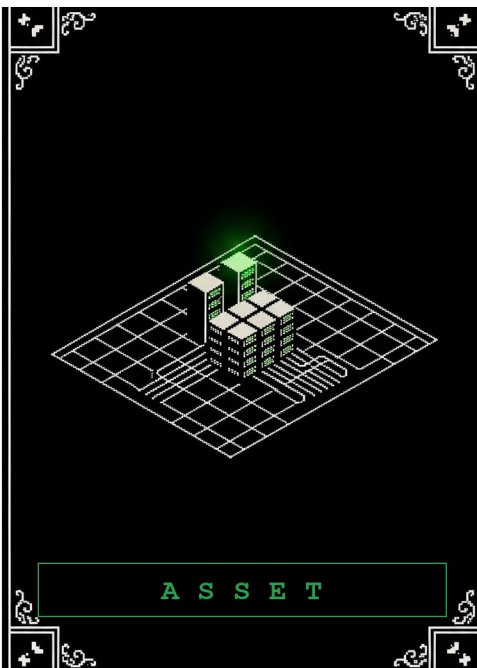
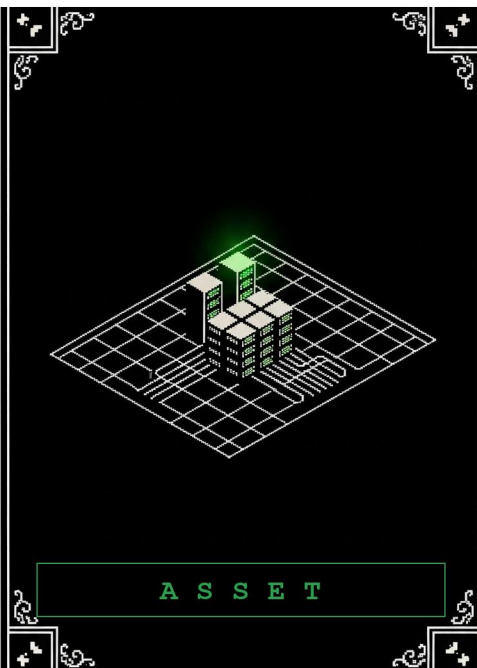
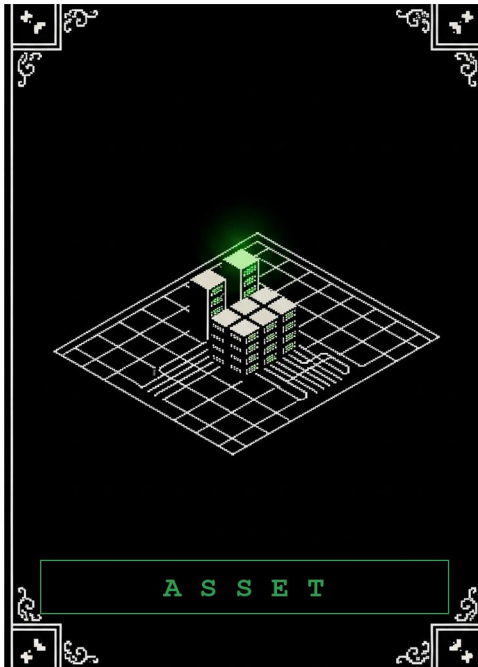
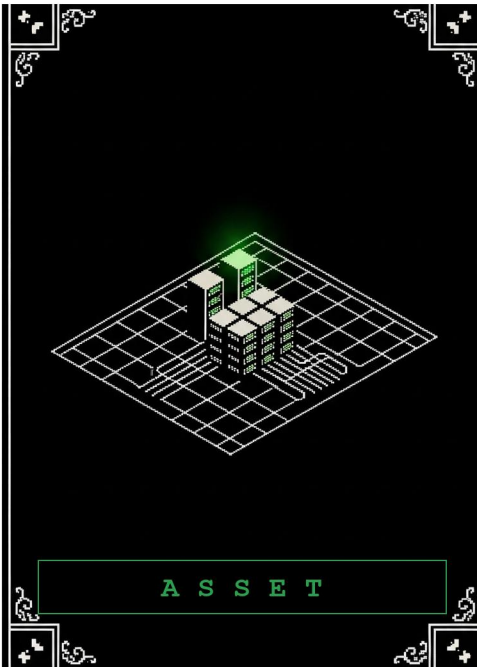
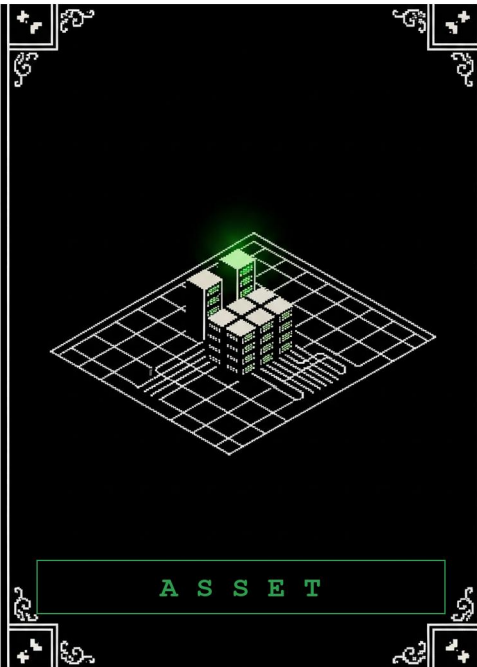
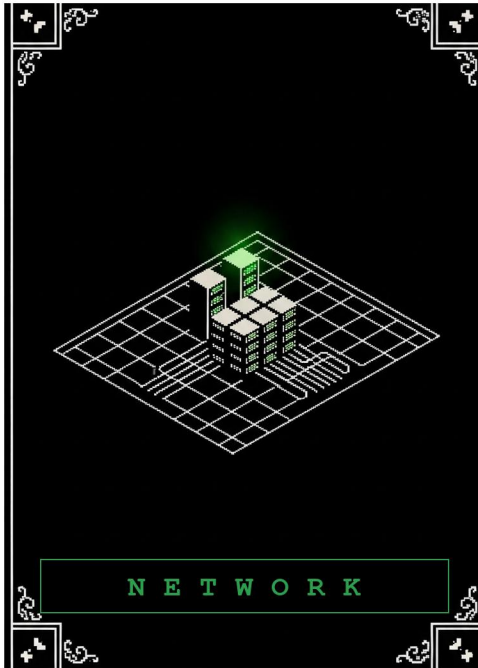
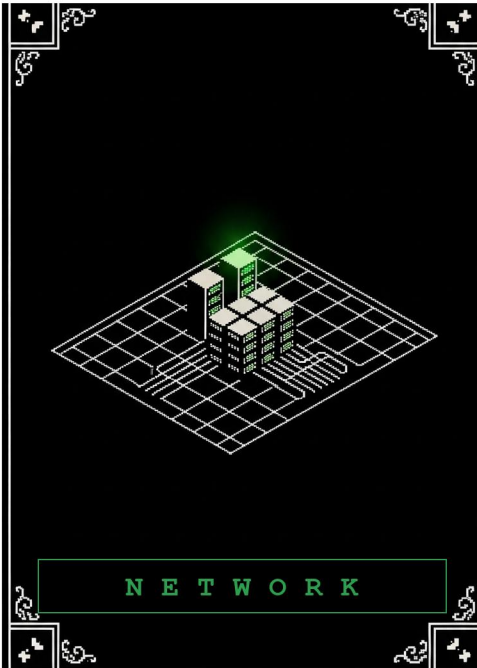
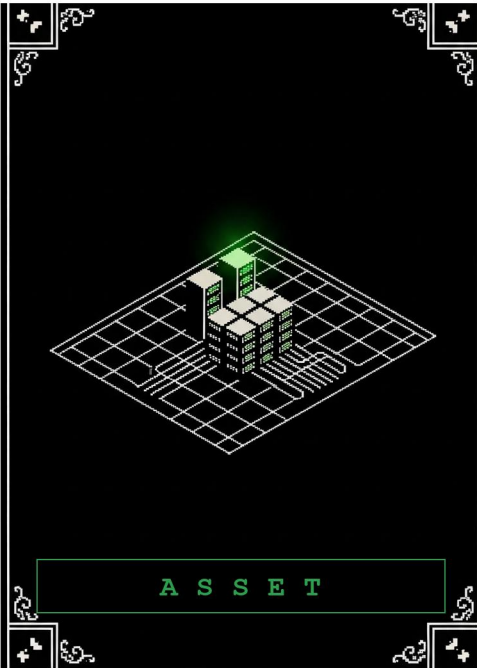
DEPENDENCIES

Requires off-site backup location (geographically separated); Requires immutable storage (WORM or cloud versioning); Requires regular backup restore testing; Requires separate backup credentials;

TEAM DESIGN VALIDATION

✓ Must Include: Backup Server with off-site capability ✓ Must Test: Recovery procedures (quarterly) ✓ Must Implement: 3-2-1 strategy ✗ Failure Condition (v2.2): No Backup Server = automatic FAIL on the Disaster Recovery requirement, recorded as a CRITICAL gap (not an instant game loss – but ransomware in later modules becomes unrecoverable)

INCIDENT ZERO - NETWORK BUILDING



ASSET CARD

ASSET-08

VPN/REMOTE ACCESS

BUSINESS FUNCTION: Secure remote access for employees and contractors

CRITICALITY: Medium (became High during COVID pandemic)

IMPACT IF DOWN: Moderate (remote workers cannot work)

COMPLIANCE REQUIREMENTS: MFA (various standards), encryption, audit logging

DESCRIPTION

VPN or similar remote access solution for employees working from home, traveling, or off-site. Remote access expands attack surface but is necessary for modern workforce.

NETWORK REQUIREMENTS

Device: VPN Gateway (SEC-05) at network perimeter; Protection: MFA required for all VPN access; Optional: Conditional access policies (restrict access by device/location);

SECURITY CONSIDERATIONS

VPN is attractive attack target (Credential Abuse); Weak VPN credentials easily brute-forced (must use MFA); Compromised home computer connecting via VPN = internal network at risk; VPN traffic must be encrypted; VPN access must be logged and audited;

DEFENSES/ENGINES

Requires Domain Controller for user authentication; Requires MFA (cannot rely on password alone!); Requires endpoint security on remote devices; Requires SIEM monitoring of VPN access;

TEAM DESIGN VALIDATION

✓ Should Include: VPN Gateway for remote access ✓ Must Implement: MFA for VPN access ✓ Should Monitor: VPN access logs in SIEM ✗ Failure Condition: Weak VPN security (no MFA) = credential attack vector

INCIDENT ZERO - NETWORK BUILDING

ARCHITECTURE CARD

ARCH-01

FLAT NETWORK (TRADITIONAL)

COST: 0 Budget

COMPLEXITY: 1/5 (very simple)

SECURITY POSTURE: Low

PERFORMANCE: High (no routing/switching overhead)

DESCRIPTION

All systems connected to same network segment (same subnet, same broadcast domain). No network segmentation-everything can talk to everything. Traditional small office network.

CHARACTERISTICS

All systems on same IP subnet (e.g., 192.168.1.0/24); Single broadcast domain; No layer 3 routing between segments; Firewall only at perimeter, not internal;

WHAT THIS MEANS FOR SECURITY

Advantages: Simple to set up and manage, low cost; **Disadvantages:** Lateral movement is trivial (attacker on user system can reach database server directly); **Implication:** If any system is compromised, entire network is at risk;

WHO USES THIS

Small offices with <50 people; Non-security-sensitive organizations; Organizations where ease of use matters more than security;

DEFENSES REQUIRED

Stronger endpoint protection (must protect each individual system); User security training (social engineering becomes primary attack vector); Cannot rely on network-level controls;

AGAINST INCIDENT RESPONSE THREATS

T-04 (Lateral Movement): Trivially successful (same network); T-06 (Mimikatz): Once DC is compromised, entire network is accessible; T-11 (Data Exfil): No segmentation to stop data movement;

INCIDENT ZERO - NETWORK BUILDING

ARCHITECTURE CARD

ARCH-02

SEGMENTED 3-ZONE (DMZ MODEL)

COST: 0 Budget

COMPLEXITY: 2/5 (simple but requires planning)

SECURITY POSTURE: Medium

PERFORMANCE: Medium (slight routing overhead)

DESCRIPTION

Network divided into three logical zones with firewall rules between them. This is the most common network architecture for medium-sized organizations.

THREE ZONES

1. DMZ (Demilitarized Zone) – Internet-facing systems Email Server, Web Server; Direct internet access controlled via firewall; If compromised, firewall prevents spread to internal zones; 2. Internal Zone – Business systems File Server, Database Server, User Workstations; Can reach DMZ for legitimate purposes; Cannot reach Admin Zone; 3. Admin Zone – Administrative access and privileged systems Domain Controller, Backup Server; Only reachable from specific admin workstations; Contains most sensitive access;

FIREWALL RULES

Internet – DMZ: Allowed (limited ports); DMZ – Internal: Blocked (one-way dependency if needed); Internal – Admin: Blocked (strict isolation); Admin – Internal: Allowed (admin management of internal systems); Admin – DMZ: Allowed (admin management of DMZ);

WHAT THIS MEANS FOR SECURITY

Advantages: Limits lateral movement (attacker on web server can't reach database server directly); **Disadvantages:** More complex to design and manage;

WHO USES THIS

Most medium-sized organizations (50-500 employees); Organizations with some web/email presence; Organizations that want segmentation without extreme complexity;

AGAINST INCIDENT RESPONSE THREATS

T-04 (Lateral Movement): Firewall rules block direct SMB access between zones; attacker must find alternate path; T-06 (Mimikatz): DC is in Admin Zone, isolated from compromised internal system; T-11 (Data Exfil): Must exit through firewall, can be monitored;

INCIDENT ZERO - NETWORK BUILDING

ARCHITECTURE CARD

ARCH-03

FULLY ISOLATED (ZERO TRUST MODEL)

COST: 12 Budget

COMPLEXITY: 4/5 (complex, requires careful design)

SECURITY POSTURE: Very High

PERFORMANCE: Lower (strict controls add latency)

GOVERNANCE: Requires change management process for any new firewall rules

DESCRIPTION

Network divided into many small segments, each with strict firewall rules. No implicit trust based on network location-every connection is verified. Approximates zero-trust architecture.

SEGMENT ISOLATION

Every major system or group gets its own segment; Database server isolated from file server; Email server isolated from web server; User workstations isolated from each other (per-user or small group segments); Development isolated from production; Admin segment for domain controllers only; Legacy systems isolated from modern systems;

FIREWALL RULES

Default deny: Any traffic not explicitly allowed is blocked; Explicit allows: Every needed connection has a specific rule; Unidirectional: Rules are directional (client-server, not server-client); Port specific: Rules specify exact port, not ranges;

WHAT THIS MEANS FOR SECURITY

Advantages: Lateral movement is nearly impossible-even if one system is compromised, firewall blocks reach to others; **Disadvantages:** very complex to design, expensive to implement, difficult to troubleshoot when legitimate traffic is blocked;

WHO USES THIS

Large enterprises with security teams; Organizations with strict compliance requirements (finance, healthcare, government); Organizations that assume breach and plan accordingly;

AGAINST INCIDENT RESPONSE THREATS

T-04 (Lateral Movement): Firewall blocks attempt immediately; attacker cannot move; T-06 (Mimikatz): Even with DC credentials, accessing other systems requires approval; T-11 (Data Exfil): Exfil traffic blocked by firewall rules;

INCIDENT ZERO - NETWORK BUILDING

ARCHITECTURE CARD

ARCH-04

CLOUD HYBRID (MIXED ON-PREMISES & CLOUD)

COST: 8 Budget

COMPLEXITY: 3/5 (cloud adds complexity)

SECURITY POSTURE: Medium-High (cloud provider handles some security)

PERFORMANCE: Medium (internet latency for cloud communication)

DESCRIPTION

Organization has both on-premises infrastructure AND cloud resources. Some applications run on-premises, others run in cloud (AWS, Azure, GCP).

CONNECTIVITY METHODS

1. VPN: Encrypted tunnel over internet (slower, cheaper) 2. Direct Connect: Dedicated network connection (faster, more expensive)

WHAT THIS MEANS FOR SECURITY

Advantages: Flexibility (use right tool for each workload), scalability; **Disadvantages:** New attack surface (cloud APIs, IAM), credential management across platforms;

CLOUD-SPECIFIC RISKS

Misconfigured S3 buckets (public read access); Cloud IAM overly permissive (too much access); Cloud API keys in source code; Data residency in unexpected regions;

WHO USES THIS

Organizations transitioning to cloud (lift-and-shift); Organizations with variable load (burst to cloud); Organizations with development in cloud, production on-prem;

AGAINST INCIDENT RESPONSE THREATS

T-04 (Lateral Movement): Can pivot from on-prem to cloud via cloud APIs; T-08 (Cloud breach): New threat class specific to cloud; T-13 (Misconfiguration): Cloud-specific attack not in traditional scenarios;

INCIDENT ZERO - NETWORK BUILDING

ARCHITECTURE CARD

ARCH-05

CLOUD FIRST (CLOUD-ONLY INFRASTRUCTURE)

COST: 6 Budget

COMPLEXITY: 2/5 (cloud provider manages complexity)

SECURITY POSTURE: Medium (cloud provider security + customer configuration)

PERFORMANCE: Excellent (cloud provider optimization)

DESCRIPTION

All infrastructure is cloud-based. No on-premises data center. Applications, data, and users all in cloud (AWS, Azure, GCP, or SaaS).

DEPLOYMENT MODELS

1. IaaS (Infrastructure as a Service): You manage VMs, they manage infrastructure

2. PaaS (Platform as a Service): You manage app, they manage platform

3. SaaS (Software as a Service): Vendor manages everything (Microsoft 365, Salesforce, Slack)

CLOUD PROVIDER RESPONSIBILITIES

Physical security of data centers; Network infrastructure; Hardware maintenance; Some security controls (network, storage);

CUSTOMER RESPONSIBILITIES

IAM configuration (who can access what); Network configuration (security groups, VPCs); Encryption keys (customer-managed or provider-managed); Application security;

WHAT THIS MEANS FOR SECURITY

Advantages: Offload infrastructure security to cloud provider, auto-scaling, built-in redundancy; **Disadvantages:** New threat landscape (cloud-specific attacks, misconfiguration);

CLOUD-SPECIFIC RISKS

IAM overly permissive (everyone can do everything); Public buckets/storage (data visible to internet); Unused resources (exposed services); Cross-account/cross-tenant misconfiguration; Cloud API abuse (stolen credentials);

WHO USES THIS

Startups (no on-prem infrastructure needed); SaaS vendors (cloud is core offering); Organizations with distributed teams (no office); Modern organizations building on cloud-native architecture;

CONTINUED IN MODULE RULES

INCIDENT ZERO - NETWORK BUILDING

